

Website Vulnerability Scanner Report

✓ <https://aadhaarngo.org/>

! The Light Website Scanner didn't check for critical issues like SQLi, XSS, Command Injection, XXE, etc.
[Upgrade to run Deep scans with 40+ tests](#) and detect more vulnerabilities.

Summary

Overall risk level:

Medium

Risk ratings:

Critical:	0
High:	0
Medium:	1
Low:	7
Info:	4

Scan information:

Start time:	Jun 03, 2026 / 23:25:37 UTC+0530
Finish time:	Jun 03, 2026 / 23:26:16 UTC+0530
Scan duration:	39 sec
Tests performed:	40
Scan status:	Finished

Findings

🚩 Vulnerabilities found for bootstrap 4.1.3 port 443/tcp

CVE	CVSS	EPSS Score	EPSS Percentile	Summary
CVE-2024-6531	6.4	0.00072	0.22588	A vulnerability has been identified in Bootstrap that exposes users to Cross-Site Scripting (XSS) attacks. The issue is present in the carousel component, where the data-slide and data-slide-to attributes can be exploited through the href attribute of an <a> tag due to inadequate sanitization. This vulnerability could potentially enable attackers to execute arbitrary JavaScript within the victim's browser.

▼ Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Since the vulnerabilities were discovered using only version-based testing, the risk level for this finding will not exceed 'high' severity. Critical risks will be assigned to vulnerabilities identified through accurate active testing methods.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

EPSS score : 0.00072
EPSS percentile : 0.22588
CISA KEV: False
CVE : [CVE-2024-6531](#)
CVSS V3 : 6.4
CWE : [CWE-1035](#)

🚩 Missing security header: Referrer-Policy port 443/tcp

CONFIRMED

URL	Evidence
-----	----------

https://aadhaarngo.org/	Response headers do not include the Referrer-Policy HTTP security header as well as the <meta> tag with name 'referrer' is not present in the response. Request / Response
---	---

▼ Details

Risk description:

The risk is that if a user visits a web page (e.g. "http://example.com/pricing/") and clicks on a link from that page going to e.g. "https://www.google.com", the browser will send to Google the full originating URL in the **Referer** header, assuming the Referrer-Policy header is not set. The originating URL could be considered sensitive information and it could be used for user tracking.

Recommendation:

The Referrer-Policy header should be configured on the server side to avoid user tracking and inadvertent information leakage. The value **no-referrer** of this header instructs the browser to omit the Referer header entirely.

References:

https://developer.mozilla.org/en-US/docs/Web/Security/Referer_header:_privacy_and_security_concerns

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 **Missing security header: Strict-Transport-Security**

CONFIRMED

port 443/tcp

URL	Evidence
https://aadhaarngo.org/	Response headers do not include the HTTP Strict-Transport-Security header Request / Response

▼ Details

Risk description:

The risk is that lack of this header permits an attacker to force a victim user to initiate a clear-text HTTP connection to the server, thus opening the possibility to eavesdrop on the network traffic and extract sensitive information (e.g. session cookies).

Recommendation:

The Strict-Transport-Security HTTP header should be sent with each HTTPS response. The syntax is as follows:

Strict-Transport-Security: max-age=<seconds>[; includeSubDomains]

The parameter **max-age** gives the time frame for requirement of HTTPS in seconds and should be chosen quite high, e.g. several months. A value below 7776000 is considered as too low by this scanner check.

The flag **includeSubDomains** defines that the policy applies also for sub domains of the sender of the response.

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 **Missing security header: X-Content-Type-Options**

CONFIRMED

port 443/tcp

URL	Evidence
https://aadhaarngo.org/	Response headers do not include the X-Content-Type-Options HTTP security header Request / Response

▼ Details

Risk description:

The risk is that lack of this header could make possible attacks such as Cross-Site Scripting or phishing in Internet Explorer browsers.

Recommendation:

We recommend setting the X-Content-Type-Options header such as **X-Content-Type-Options: nosniff**.

References:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>

Classification:

CWE : [CWE-693](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Unsafe security header: Content-Security-Policy

CONFIRMED

port 443/tcp

URL	Evidence
https://aadhaarngo.org/	Response headers include the HTTP Content-Security-Policy security header with the following security issues: <pre>script-src: script-src directive is missing. default-src: The default-src directive should be set as a fall-back when other restrictions have not been specified. object-src: Missing object-src allows the injection of plugins which can execute JavaScript. We recommend setting it to 'none'. base-uri: Missing base-uri allows the injection of base tags. They can be used to set the base URL for all relative (script) URLs to an attacker controlled domain. We recommend setting it to 'none' or 'self'.</pre> Request / Response

▼ Details**Risk description:**

For example, if the unsafe-inline directive is present in the CSP header, the execution of inline scripts and event handlers is allowed. This can be exploited by an attacker to execute arbitrary JavaScript code in the context of the vulnerable application.

Recommendation:

Remove the unsafe values from the directives, adopt nonces or hashes for safer inclusion of inline scripts if they are needed, and explicitly define the sources from which scripts, styles, images or other resources can be loaded.

References:

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>

Classification:

CWE : [CWE-1021](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

🚩 Robots.txt file found

CONFIRMED

port 443/tcp

URL
https://aadhaarngo.org/robots.txt

▼ Details**Risk description:**

There is no particular security risk in having a robots.txt file. However, it's important to note that adding endpoints in it should not be considered a security measure, as this file can be directly accessed and read by anyone.

Recommendation:

We recommend you to manually review the entries from robots.txt and remove the ones which lead to sensitive locations in the website (ex. administration panels, configuration files, etc).

References:

<https://www.theregister.co.uk/2015/05/19/robotstxt/>

Classification:

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Exposure of Sensitive Information

port 443/tcp

UNCONFIRMED ⓘ

URL	Method	Parameters	Evidence
https://aadhaarngo.org/	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Credit Card Number: 2644536267352236 Request / Response

Details

Risk description:

The risk exists that sensitive personal information within the application could be accessed by unauthorized parties. This could lead to privacy violations, identity theft, or other forms of personal or corporate harm.

Recommendation:

Compartmentalize the application to have "safe" areas where trust boundaries can be unambiguously drawn. Do not allow sensitive data to go outside of the trust boundary and always be careful when interfacing with a compartment outside of the safe area.

Classification:

CWE : [CWE-201](#)

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Server software and technology found

port 443/tcp

UNCONFIRMED ⓘ

Software / Version	Category
 Clipboard.js	JavaScript libraries
 Contact Form 7 6.1.6	WordPress plugins, Form builders
 Elementor 4.1.1	Page builders, WordPress plugins
 Google Font API	Font scripts
 Bootstrap 4.1.3	UI frameworks
 jQuery Migrate 3.4.1	JavaScript libraries
 core-js 3.46.0	JavaScript libraries
 Google Analytics	Analytics
 HTTP/3	Miscellaneous
 imagesLoaded 5.0.0	JavaScript libraries
Isotope	JavaScript libraries
 jQuery 3.7.1	JavaScript libraries
 jQuery UI 1.13.3	JavaScript libraries
Slick	JavaScript libraries
 Masonry	JavaScript libraries
 MySQL	Databases
 OWL Carousel	JavaScript libraries
 PHP 8.1.34	Programming languages
 Site Kit 1.180.0	Analytics, WordPress plugins
 DoubleClick Floodlight	Advertising

 WooCommerce 10.8.1	Ecommerce, WordPress plugins
 WordPress 7.0	CMS, Blogs
 WordPress Multisite	Hosting
 AMP	JavaScript frameworks
 Google AdSense	Advertising
 Google Tag Manager	Tag managers
 Hostinger	Hosting
 Lodash 1.13.8	JavaScript libraries
 RSS	Miscellaneous

▼ Details

Risk description:

The risk is that an attacker could use this information to mount specific attacks against the identified software type and version.

Recommendation:

We recommend you to eliminate the information which permits the identification of software platform, technology, server and operating system: HTTP server headers, HTML meta information, etc.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server.html

Classification:

CWE : [CWE-200](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)



Security.txt file is missing

CONFIRMED

port 443/tcp

URL

Missing: <https://aadhaarngo.org/.well-known/security.txt>

▼ Details

Risk description:

There is no particular risk in not having a security.txt file for your server. However, this file is important because it offers a designated channel for reporting vulnerabilities and security issues.

Recommendation:

We recommend you to implement the security.txt file according to the standard, in order to allow researchers or users report any security issues they find, improving the defensive mechanisms of your server.

References:

<https://securitytxt.org/>

Classification:

CWE : [CWE-1188](#)

OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)

OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)

OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)



HTTP OPTIONS enabled

CONFIRMED

port 443/tcp

URL	Method	Summary
-----	--------	---------

https://aadhaarngo.org/	OPTIONS	We did a HTTP OPTIONS request. The server responded with a 200 status code and the header: Allow: OPTIONS,HEAD,GET,POST Request / Response
---	---------	---

▼ Details

Risk description:

The only risk this might present nowadays is revealing debug HTTP methods that can be used on the server. This can present a danger if any of those methods can lead to sensitive information, like authentication information, secret keys.

Recommendation:

We recommend that you check for unused HTTP methods or even better, disable the OPTIONS method. This can be done using your webserver configuration.

References:

<https://techcommunity.microsoft.com/t5/iis-support-blog/http-options-and-default-page-vulnerabilities/ba-p/1504845>
<https://docs.nginx.com/nginx-management-suite/acm/how-to/policies/allowed-http-methods/>

Classification:

CWE : [CWE-16](#)
OWASP Top 10 - 2017 : [A6 - Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A5 - Security Misconfiguration](#)
OWASP Top 10 - 2025 : [A02 - Security Misconfiguration](#)

Email Address Exposure

port 443/tcp

UNCONFIRMED 

URL	Method	Parameters	Evidence
https://aadhaarngo.org/	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Email Address: aadhaarngo@gmail.com Request / Response
https://aadhaarngo.org/wp-json/wp/v2/pages	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Email Address: taadhaarngo@gmail.com Request / Response

▼ Details

Risk description:

The risk is that exposed email addresses within the application could be accessed by unauthorized parties. This could lead to privacy violations, spam, phishing attacks, or other forms of misuse.

Recommendation:

Compartmentalize the application to have 'safe' areas where trust boundaries can be unambiguously drawn. Do not allow email addresses to go outside of the trust boundary, and always be careful when interfacing with a compartment outside of the safe area.

References:

https://owasp.org/Top10/A04_2021-Insecure_Design/

Classification:

CISA KEV: False
CVE : -1
CWE : [CWE-200](#)
OWASP Top 10 - 2017 : [A6: Security Misconfiguration](#)
OWASP Top 10 - 2021 : [A4: Insecure Design](#)
OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

API endpoints

port 443/tcp

UNCONFIRMED 

URL	Method	Parameters	Evidence
-----	--------	------------	----------

https://aadhaarngo.org/wp-json/wp/v2/	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Possible API endpoint found at /wp-json/wp/v2 Request / Response
https://aadhaarngo.org/wp-json/wp/v2/pages	GET	Headers: User-Agent=Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/108.0.0.0 Safari/537.36	Possible API endpoint found at /wp-json/wp/v2/pages Request / Response

▼ Details

Risk description:

These endpoints may represent an attack surface for malicious actors interested in API-specific vulnerabilities.

Recommendation:

Use the API Scanner to perform a more thorough vulnerability check for these endpoints, if an API specification is present.

Classification:

OWASP Top 10 - 2025 : [A06 - Insecure Design](#)

Scan coverage information

List of tests performed (40)

Port 443

- ✓ Scanned for version-based vulnerabilities of server-side software
- ✓ Scanned for sensitive data
- ✓ Scanned for missing HTTP header - Referrer
- ✓ Scanned for missing HTTP header - Strict-Transport-Security
- ✓ Scanned for missing HTTP header - X-Content-Type-Options
- ✓ Scanned for robots.txt file
- ✓ Scanned for website technologies
- ✓ Scanned for unsafe HTTP header Content Security Policy
- ✓ Scanned for API endpoints
- ✓ Scanned for emails
- ✓ Scanned for enabled HTTP OPTIONS method
- ✓ Scanned for absence of the security.txt file
- ✓ Scanned for client access policies
- ✓ Scanned for use of untrusted certificates
- ✓ Scanned for enabled HTTP debug methods
- ✓ Scanned for secure communication
- ✓ Scanned for directory listing
- ✓ Scanned for passwords submitted unencrypted
- ✓ Scanned for error messages
- ✓ Scanned for debug messages
- ✓ Scanned for code comments
- ✓ Scanned for missing HTTP header - Content Security Policy
- ✓ Scanned for passwords submitted in URLs
- ✓ Scanned for domain too loose set for cookies
- ✓ Scanned for mixed content between HTTP and HTTPS
- ✓ Scanned for cross domain file inclusion
- ✓ Scanned for internal error code
- ✓ Scanned for HttpOnly flag of cookie
- ✓ Scanned for Secure flag of cookie
- ✓ Scanned for login interfaces
- ✓ Scanned for secure password submission
- ✓ Scanned for OpenAPI files
- ✓ Scanned for file upload
- ✓ Scanned for SQL statement in request parameter
- ✓ Scanned for password returned in later response
- ✓ Scanned for Path Disclosure

- ✔ Scanned for Session Token in URL
- ✔ Scanned for missing HTTP header - Rate Limit
- ✔ Scanned for PEM-encoded private key material
- ✔ Scanned for partial PEM-encoded private key material

Scan parameters

target:	https://aadhaarngo.org/
scan_type:	Light
authentication:	False

Scan stats

Unique Injection Points Detected:	155
URLs spidered:	16
Total number of HTTP requests:	25
Average time until a response was received:	363ms